

Kaskadowe awarie cyber-fizyczne a infrastruktura Iranu

Streszczenie wykonawcze

Niniejszy raport **nie tworzy „strategii ataku” ani nie podaje instrukcji operacyjnych**. Zamiast tego przedstawia **defensywne, akademickie i polityczne** ujęcie zjawiska *kaskadowych awarii* (cascading failures) w skali państwa: jak powstają, dlaczego są trudne do powstrzymania, jak je modelować oraz jak zwiększać odporność infrastruktury krytycznej. Wnioski opierają się o: (a) oficjalne i recenzowane źródła dotyczące zależności infrastrukturalnych i bezpieczeństwa OT/ICS, (b) publicznie udokumentowane przypadki historyczne, (c) standardy i ramy zarządzania ryzykiem (NIST/ISA/IEC/MITRE), oraz (d) przegląd wskazanych repozytoriów GitHub jako przykładów praktyk inżynierii bezpieczeństwa (SBOM, „fail-closed” gate’y jakości, obserwowalność). ¹ ² ³

Najistotniejsza intuicja badawcza jest taka, że „kaskada” rzadko wynika z jednego punktu awarii. Zwykle jest skutkiem **sprzężeń zwrotnych** pomiędzy sektorami (energia ↔ telekomunikacja ↔ woda ↔ transport ↔ finanse ↔ zdrowie), gdzie zakłócenie w jednym obszarze **zmniejsza zdolność wykrywania i reagowania** w innych, przyspieszając rozchodzenie się skutków (np. utrata zasilania ogranicza łączność, a utrata łączności ogranicza sterowanie i odtwarzanie zasilania). Klasyczne prace o zależnościach infrastrukturalnych i o *sieciach współzależnych* pokazują, że nawet niewielka degradacja może w pewnych warunkach przejść w gwałtowną, nieproporcjonalną kaskadę. ⁴

W wymiarze politycznym i prawnym: cyberoperacje wymierzone w infrastrukturę krytyczną w skali państwa są rozpatrywane w kontekście norm ONZ dot. odpowiedzialnego zachowania państw w cyberprzestrzeni oraz zastosowania prawa międzynarodowego; równolegle badania bezpieczeństwa wymagają rygorystycznej etyki, upoważnień i koordynowanej publikacji podatności. ⁵

Ramy prawne i etyczne badań cyberbezpieczeństwa

W perspektywie prawa karnego i współpracy międzynarodowej, **nieuprawniony dostęp**, zakłócanie pracy systemów oraz nadużycia narzędzi komputerowych są w wielu jurysdykcjach penalizowane; jednym z kluczowych instrumentów harmonizujących podejście do cyberprzestępczości jest **Konwencja o cyberprzestępczości: Konwencja budapeszteńska** Rady Europy (ETS 185). ⁶ W praktyce badawczej oznacza to, że prace empiryczne na systemach produkcyjnych (zwłaszcza OT/ICS) muszą być prowadzone wyłącznie w ramach wyraźnych upoważnień, kontrolowanych środowisk testowych i zgodnych z prawem procedur.

Na poziomie norm i polityki międzynarodowej, rezolucje i procesy ONZ dotyczące bezpieczeństwa informacyjno-telekomunikacyjnego w kontekście bezpieczeństwa międzynarodowego (m.in. rezolucja ZO ONZ **70/237** oraz prace OEWG) podkreślają ryzyko wykorzystywania ICT w sposób zagrażający stabilności i integralności infrastruktury państw oraz wskazują znaczenie działań budujących zaufanie, zdolności i odpowiedzialne zachowania. ⁷ W literaturze eksperckiej (niewiążącej, ale wpływowej) istotnym punktem odniesienia jest **Tallinn Manual 2.0**, który systematyzuje, jak prawo międzynarodowe (m.in. suwerenność, zakaz interwencji, użycie siły) może być interpretowane w kontekście cyberoperacji. ⁸

W etyce badań bezpieczeństwa krytyczne są zasady „minimalizacji szkód” i „kontroli ujawniania”: jeżeli badania ujawniają defekty, powinny iść ścieżką **Coordinated Vulnerability Disclosure (CVD)**, tj. skoordynowanego procesu łączącego badacza, producenta i operatorów. Takie podejście opisują m.in. praktyki CISA ⁹ (program CVD, etapy od przyjęcia zgłoszenia do publicznego ujawnienia) oraz europejskie ujęcie ENISA ¹⁰, które wiąże CVD z odpornością ekosystemu i rolą CSIRT-ów. ¹¹ Standardy **ISO/IEC 29147** (ujawnianie) i **ISO/IEC 30111** (obsługa podatności) formalizują minimalne wymagania procesowe, w tym komunikację, terminy i role w przetwarzaniu zgłoszeń. ¹²

Lekcje z historycznych incydentów kaskadowych

Publiczne studia przypadków pokazują, że kaskady cyber-fizyczne zwykle łączą: dostęp do środowisk IT, przejście do OT/ICS, manipulację procesem lub funkcjami bezpieczeństwa oraz elementy utrudniające reakcję (np. wiper, sabotaż narzędzi administracyjnych). Ta logika jest widoczna zarówno w raportach historycznych, jak i w bazach zachowań przeciwnika dla ICS. ¹³

Stuxnet jest archetypem cyberbroni ukierunkowanej na sterowanie przemysłowe, często wskazywanym jako przykład oddziaływania na proces fizyczny (tu: infrastruktura programu nuklearnego). Analizy raportowe wskazują na wyjątkową złożoność, wieloetapowość i specjalizację pod środowiska sterowania. ¹⁴ (W tym raporcie nie rozwijam szczegółów implementacyjnych – istotne jest znaczenie precedensu: możliwość *kinetycznego* efektu poprzez warstwę cyfrową.)

Ataki na sieć energetyczną Ukraina ¹⁵ (2015) są ważnym przypadkiem kaskadowym: wyłączenia energii elektrycznej w połączeniu z działaniami w systemach wspierających (operatorzy, łączność, stacje robocze, dane) pokazały, że celem może być **ciągłość świadczenia usługi**, a nie jedynie kradzież danych. Raport „lessons learned” opracowany przez SANS i E-ISAC stał się punktem odniesienia dla obrony (m.in. wymagania dot. segmentacji, monitoringu i procedur). ¹⁶

Incydent w Kijowie (2016) związany z rodziną malware często określaną jako Industroyer/CrashOverride pokazuje kolejny etap: narzędzie projektowane do interakcji z elementami infrastruktury energetycznej oraz potencjał do wywołania skutków „kaskadowych” zależnie od warunków środowiskowych i ochrony. ¹⁷ (W raporcie defensywnym kluczowe są lekcje o *projektowaniu odporności* na działania w warstwie procesowej, nie detale protokołowe.)

Współczesnym polskim przykładem ryzyka przejścia „cyber → fizyczne procesy” jest opisywany przez CERT Polska ¹⁸ incydent z końca 2025 r. w sektorze energii, obejmujący m.in. instalacje OZE i infrastrukturę elektrociepłowniczą, gdzie wskazywano realne ryzyko przerwania ciągłości dostaw ciepła dla setek tysięcy odbiorców. ¹⁹ Ten przypadek jest istotny metodologicznie: pokazuje, że nawet bez publicznie znanych „efektów spektakularnych”, samo spięcie systemów IT/OT w wrażliwych miejscach może generować ryzyko kaskadowe.

W tle warto pamiętać, że kaskady mogą zachodzić także bez „ataku”, czysto systemowo. Praca o sieciach współzależnych przytacza m.in. awarię energetyczną we Włoszy ²⁰ (2003) oraz wtórne skutki dla sieci komunikacyjnych, ilustrując mechanizm wzajemnego „dociągania” się awarii między sektorami. ²¹

timeline

- title Wybrane zdarzenia i publikacje istotne dla kaskad cyber-fizycznych
- 2010 : Ujawnienie Stuxnet (symptomatyczny precedens cyber-fizyczny)
- 2015 : NIST SP 800-82 Rev.2 (ICS security guidance)
- 2015 : Ataki na sieć energetyczną Ukrainy (blackout, lessons learned)

2016 : Blackout Kijowa i narzędzia ICS (Industroyer/CrashOverride)
2023 : NIST SP 800-82 Rev.3 (OT Security Guide - final)
2024 : NIST CSF 2.0 (Govern + risk governance)
2025 : ENISA: Threat Landscape for Supply Chain Attacks (kontekst łańcucha dostaw)
2025 : Incydent w sektorze energii w Polsce (analiza CERT Polska)

(Chronologia i przypisania oparte na: raportach historycznych, materiałach NIST/ENISA i komunikatach CERT). ²²

Mechanizmy techniczne prowadzące do kaskad

Współzależności infrastrukturalne są „silnikiem” kaskad. Klasyczny model zależności wyróżnia różne typy (np. fizyczne, cybernetyczne, geograficzne, logiczne), a analiza kaskad wymaga uwzględnienia, że jedna infrastruktura może być jednocześnie dostawcą zasobu i konsumentem usług innej (np. energetyka potrzebuje łączności, łączność potrzebuje energii). ²³ Teoria sieci współzależnych pokazuje dodatkowo nieintuicyjny efekt: systemy połączone mogą stać się bardziej kruche niż każda sieć osobno; mała awaria może wejść w pętlę rekurencyjną i doprowadzić do fragmentacji całości. ²¹

Konwergencja IT/OT oraz specyfika ICS/SCADA. NIST ²⁴ podkreśla, że OT/ICS (SCADA, DCS, PLC) mają inne priorytety niż IT: bezpieczeństwo musi współistnieć z wymaganiami niezawodności, czasu rzeczywistego i bezpieczeństwa funkcjonalnego. ²⁵ Jednocześnie część technologii przemysłowych i protokołów historycznie projektowano dla środowisk odizolowanych, co prowadzi do ryzyk, gdy systemy są wystawiane na sieć lub zarządzane zdalnie. Analizy incydentu Industroyer wskazywały, że słabość często nie leży w „łamaniu kryptografii”, ale w dziedzictwie architektury i założeń (brak wbudowanych mechanizmów bezpieczeństwa). ²⁶

Łańcuch dostaw i kompromitacja komponentów. Do kaskad mogą prowadzić zależności od dostawców oprogramowania, sprzętu, integratorów i usług. ENISA w swoim threat landscape opisuje rosnącą wagę ataków na łańcuch dostaw oraz potrzebę włączania dostawców w mechanizmy ochrony. ²⁷ NIST rozwija to w ramach podejścia C-SCRM, wskazując, że ryzyka obejmują m.in. niewidoczność praktyk wytwarzania i integracji, a celem jest zarządzanie ryzykiem na wielu poziomach organizacji. ²⁸

W praktykach inżynierskich (tu: przegląd repozytorium „sbom”) widać wzorzec obronny: automatyzacja tworzenia i oceny **SBOM** (Software Bill of Materials) oraz skanowania podatności w pipeline CI/CD, aby ograniczać ryzyko „nieznanych zależności” i szybciej lokalizować komponenty dotknięte podatnością.

² ²⁹

Routing i zależności sieciowe (BGP). Systemowa kaskada w cyberprzestrzeni może powstać nie przez włamanie, lecz przez zaburzenia routingu: BGP jest kluczowym protokołem wymiany osiągalności pomiędzy systemami autonomicznymi. ³⁰ Dokument BCP o operacjach i bezpieczeństwie BGP zbiera praktyki ograniczające ryzyko przypadkowych lub celowych zakłóceń routingu (m.in. filtracje prefiksów, limity, ochrona sesji). ³¹ Wzmocnienia takie jak RPKI (walidacja pochodzenia) są wdrażane przez rejestry internetowe jako mechanizm wzmacniający bezpieczeństwo decyzji routingu. ³² Inicjatywy branżowe (MANRS) popularyzują dobre praktyki walidacji i ograniczania przejęć tras. ³³ (W raporcie defensywnym kluczowe jest to, że ryzyko routingu jest *systemowe* i może propagować się poza pojedynczą organizację.)

Wektory propagacji i „rozchodzenie się” skutków. W obronie użyteczne jest ujęcie zachowań przeciwnika jako klas technik (bez wchodzenia w szczegóły wykonawcze). Baza ATT&CK dla ICS

porządkuje typowe taktyki i techniki widziane w środowiskach przemysłowych, co ułatwia mapowanie telemetrii i kontroli bezpieczeństwa. ³⁴

flowchart TD

```
A[Zakłócenie w sektorze A] --> B[Utrata zasobu / degradacja usługi]
B --> C[Spadek widoczności i sterowalności]
C --> D[Opóźnione / nieskuteczne reagowanie]
D --> E[Efekt wtórny w sektorze B]
E --> F[Sprężenie zwrotne do sektora A]
B --> G[Wpływ na łańcuch dostaw / zależne systemy]
B --> H[Zaburzenia routingu / łączności]
```

(Mechanizm sprzężeń i zależności infrastrukturalnych opisują ramy interdependency oraz literatura o sieciach współzależnych). ⁴

Modele zagrożeń i metody oceny ryzyka infrastruktury państwowej

Dla analizy odporności infrastruktury w skali państwa praktyczna jest kombinacja: **ram zarządzania ryzykiem**, **modelowania zależności** oraz **analizy scenariuszowej** (stress testing). ³⁵

Rama NIST Cybersecurity Framework ³⁶ w wersji 2.0 kładzie nacisk na mierzalne „outcomes” oraz dodaje funkcję **Govern**, co pomaga traktować cyberbezpieczeństwo jako element zarządzania ryzykiem organizacji i państwa (w tym ryzyka dostawców). ³⁷ Dla OT/ICS niezbędne jest „dociążenie” tych ram specyfiką sterowania procesem; NIST SP 800-82 (OT Security Guide) jest jednym z podstawowych przewodników, podkreślając bezpieczeństwo przy zachowaniu wymogów niezawodności i bezpieczeństwa procesowego. ²⁵

Dla środowisk przemysłowych i infrastruktury krytycznej istotny jest standard International Society of Automation ³⁸ /IEC 62443, który systematyzuje wymagania i procesy „od programu bezpieczeństwa po poziomy zabezpieczeń”, obejmując także ryzyko w projektowaniu systemu (np. część 3-2 dot. oceny ryzyka dla projektu). ³⁹ W praktyce państwowej standardy takie są przydatne jako wspólny język (dla operatorów, integratorów, dostawców). ⁴⁰

Dla modelowania zachowań przeciwnika (z perspektywy obrony) użyteczna jest baza Identity[["organization","MITRE","us not-for-profit r&d org"]] ATT&CK dla ICS: umożliwia budowę scenariuszy testowych i mapowanie kontroli „detekcja–prewencja–reakcja” do klas zachowań, bez wchodzenia w szczegóły eksploatacyjne. ⁴¹

Warto zauważyć również znaczenie „inżynierskich” narzędzi odporności: w przeglądanych repozytoriach pojawiają się wzorce typu **fail-closed gate** (blokowanie wdrożeń przy naruszeniu inwariantów jakości i bezpieczeństwa), ujednolicone potoki SAST i telemetria zmian (Δ -metryki) – to przykłady praktyk, które redukują ryzyko wprowadzania podatności i ułatwiają dochodzenia incydentowe. ³ ⁴²

flowchart LR

```
G[Governance: cele, apetyt na ryzyko, odpowiedzialności] -->
I[Ideentyfikacja zasobów i zależności międzysektorowych]
I --> T[Threat modeling: klasy zachowań przeciwnika (defensywnie)]
```

T --> C[Kontrola: OT/ICS, łańcuch dostaw, routing, IR]
 C --> M[Metryki odporności: MTDD/MTTR, rozmiar kaskady, SLA usług]
 M --> G

(Ujęcie zgodne z CSF 2.0 jako cyklem zarządzania ryzykiem oraz z podejściem OT security guidance). ⁴³

Prawdopodobne sektory infrastruktury krytycznej w Iranie i ich zależności

Poniższe rozpoznanie ma charakter **makro-analityczny**: nie zakłada dostępu do architektur, topologii ani konfiguracji systemów w Iranie (to pozostaje **nieokreślone**). Opiera się na publicznych danych sektorowych oraz typowych wzorcach technologicznych dla infrastruktury krytycznej. ⁴⁴

Warto zacząć od energii, bo jest to zwykle „węzeł centralny” kaskad. Dane U.S. Energy Information Administration ⁴⁵ wskazują, że w 2022 r. Iran wytworzył ok. 361 TWh energii elektrycznej netto, z dominacją paliw kopalnych (ok. 93%), a gaz ziemny jest głównym paliwem generacji (raport podaje ~85% udziału gazu w wytwarzaniu). ⁴⁶ Taka struktura implikuje wysoką wrażliwość na problemy w łańcuchu gaz-elektrownie-sieć przesyłowa-dystrybucja, a także silne sprzężenia z transportem paliw i zarządzaniem popytem (szczyty sezonowe). ⁴⁶

Z perspektywy kaskad, kluczowe są zależności: energetyka wspiera łączność (stacje bazowe, węzły transmisyjne), wodę (pompy, uzdatnianie), zdrowie (szpitale), finanse (systemy płatności) i transport (sygnalizacja, paliwa). Równocześnie łączność i IT wspierają energetykę (telemetria, dyspozycja, automatyka), co tworzy klasyczne sprzężenie dwukierunkowe opisywane w analizach interdependency. ⁴⁷

Tabela poniżej zestawia prawdopodobne sektory oraz ich ekspozycję i potencjał kaskadowy w sposób **ogólny** (nie specyficzny dla unikatowych rozwiązań irańskich).

Sektor	Typowe systemy sterowania / IT (wysoki poziom)	Typowa ekspozycja „publiczna” (trend)	Potencjał kaskadowy (przykładowo)
Energia (elektryczność, O&G)	OT/ICS: SCADA/DCS/PLC, systemy dyspozytorskie; IT: systemy utrzymania i rozliczeń	Rosnąca (zdalny dostęp, integracje IT/OT), ale często częściowo segmentowana	Bardzo wysoki: wpływa na wszystkie sektory; utrudnia odtwarzanie usług, gdy spada łączność
Woda i ścieki	SCADA/PLC, telemetria, automatyka pomp i uzdatniania	Średnia: zdalne utrzymanie + podatność na błędne konfiguracje	Wysoki: brak wody/presji wpływa na zdrowie, przemysł, chłodzenie, bezpieczeństwo publiczne

Sektor	Typowe systemy sterowania / IT (wysoki poziom)	Typowa ekspozycja „publiczna” (trend)	Potencjał kaskadowy (przykładowo)
Telekomunikacja i internet	Core sieci, OSS/BSS, systemy zarządzania; zależność od energii i routingu	Wysoka: usługi masowe, punkty styku z internetem	Bardzo wysoki: bez łączności spada sterowalność energetyki/wody, rośnie chaos informacyjny
Finanse i płatności	Systemy bankowe, rozliczeniowe, kanały elektroniczne	Wysoka: usługi online, zależność od łączności	Wysoki: przerwy w płatnościach destabilizują logistykę, dostawy i zaufanie społeczne
Transport (kolej, drogi, porty, lotnictwo)	Sterowanie ruchem, systemy biletowe i logistyczne, telemetria	Średnia do wysokiej	Wysoki: opóźnia dostawy paliw, żywności i części; utrudnia naprawy energetyki
Ochrona zdrowia	HIS/EMR, sieci urządzeń, systemy wsparcia życia (zależne od energii)	Średnia: rosnąca cyfryzacja i integracje	Wysoki: ryzyko dla życia i bezpieczeństwa; krytyczne czasy odtworzenia
Administracja i łączność kryzysowa	Systemy powiadamiania, centra zarządzania, rejestry	Średnia	Wysoki: koordynacja reakcji, wiarygodność informacji, zdolność do zarządzania kryzysem

(Typologia OT/ICS i jej wymagania bezpieczeństwa: NIST OT/ICS guidance; standardy ISA/IEC 62443; ryzyko ekspozycji urządzeń OT „z internetu” obserwowane przez CERT). ⁴⁸

flowchart TB

```

E[Energia] --> T[Telekomunikacja]
E --> W[Woda i ścieki]
E --> H[Zdrowie]
E --> F[Finanse]
E --> Tr[Transport]

T --> E
T --> F
T --> H
Tr --> E
W --> H
F --> Tr

```

(Ujęcie zależności zgodne z klasycznymi ramami interdependency oraz wiedzą o OT/ICS). ⁴⁷

Odporność, obrona i zarządzanie kryzysowe

„Odporność na kaskady” wymaga równoczesnego podejścia technicznego, organizacyjnego i regulacyjnego: pojedyncza kontrola (np. firewall) nie wystarczy, bo kaskady są efektem sprzężeń w systemie-systemów. ⁴⁹

W warstwie OT/ICS, przewodniki NIST akcentują m.in. segmentację, kontrolę zdalnego dostępu, monitorowanie oraz dopasowanie kontroli do wymagań bezpieczeństwa i niezawodności procesowej. ²⁵ W polskim kontekście CERT Polska wprost wskazuje problem urządzeń OT/ICS wystawionych bezpośrednio do internetu (często przez routery komórkowe) i publikuje zestaw rekomendacji wzmacniających ochronę. ⁵⁰ Z perspektywy kaskad kluczowe jest ograniczanie „przeskoku” IT→OT, a gdy zdalny dostęp jest konieczny – jego silne ustrukturyzowanie (tożsamość, monitoring, zasada najmniejszych uprawnień, rejestrowanie sesji). ⁵¹

W warstwie łańcucha dostaw należy łączyć działania strategiczne (C-SCRM) i taktyczne (SBOM, skanowanie zależności, kontrola integralności artefaktów). NIST opisuje C-SCRM jako zestaw praktyk obejmujących identyfikację, ocenę i mitygację ryzyk wynikających z niewidoczności procesów wytwarzania i integracji technologii. ²⁸ ENISA podkreśla, że ochrona musi obejmować relacje z dostawcami oraz metody reagowania na ataki supply chain. ²⁷ Praktycznym wzorcem jest automatyzacja SBOM i „bramek” bezpieczeństwa w CI/CD (przykładowo: repozytorium „sbom” opisuje integrację generacji SBOM i skanowania jako element pipeline). ²⁹ ²

W obszarze architektury i wdrożeń (zwłaszcza w środowiskach chmurowo-kontenerowych) znaczenie mają „warstwy ochrony” takie jak ograniczanie uprawnień, segmentacja sieciowa, mTLS w komunikacji usług i bezpieczne zarządzanie sekretami. Przykładowe kompendium dobrych praktyk (Kubernetes/Istio/monitoring) w repozytorium „swarm” pokazuje, jak te elementy składają się w spójny model defensywny (RBAC, network policies, mTLS, audyt). ⁵²

W warstwie routingu i zależności operatorskich, BCP o bezpieczeństwie BGP (RFC 7454) podkreśla rolę filtracji prefiksów, limitów i ochrony sesji dla redukcji zakłóceń przypadkowych i intencjonalnych. ³¹ RPKI i walidacja pochodzenia stanowią mechanizmy systemowe wspierające ograniczanie przejęć tras, implementowane przez operatorów i wspierane przez RIR-y (np. RIPE NCC). ³²

Zarządzanie incydem i odbudową (Respond/Recover) powinno być projektowane „pod kaskady”: planowanie alternatywnych kanałów łączności, procedury manualne w OT (tam, gdzie to bezpieczne), priorytetyzacja usług (np. szpitale, woda, dyspozycja energii) oraz ćwiczenia międzysektorowe. Logika CSF 2.0 (w tym funkcja Govern) jest użyteczna do ustawienia odpowiedzialności i mierników skuteczności. ⁵³

Wreszcie: bezpieczna polityka publikacji i wymiany informacji – CVD – jest elementem odporności ekosystemu, bo skraca „okno wykorzystania” podatności i ujednolica komunikację. ENISA i CISA opisują CVD jako mechanizm wzmacniający ochronę użytkowników i ograniczający skutki eksploatacji. ⁵⁴ ISO/IEC 29147 i 30111 formalizują minimalne procesy, które organizacje (w tym dostawcy) powinny mieć, aby obsługiwać zgłoszenia i publikować poprawki w sposób odpowiedzialny. ¹²

Program badawczy i pytania otwarte

Badania nad kaskadami w skali państwa są trudne, bo prawdziwe dane topologiczne i konfiguracyjne są zwykle niejawne; mimo to istnieją bezpieczne i wartościowe metody pracy oparte na symulacji, analizie statystycznej i ćwiczeniach. ⁵⁵

Najważniejsze pytania otwarte (defensywne) obejmują: jak mierzyć „krytyczność” węzłów w sieciach współzależnych w warunkach niepełnej informacji; jak kwantyfikować ryzyko przejścia IT→OT w zależności od architektury i dojrzałości procesu; jak uwzględniać łańcuch dostaw jako dynamiczny graf zależności; oraz jak prognozować progi przejścia („phase transition”) od degradacji do kaskady. ⁵⁶

Przykładowe **nieoperacyjne** eksperymenty badawcze i symulacje (bez testów na realnych systemach) to:

Modelowanie sieci współzależnych (energia–telekom–woda) w duchu literatury o interdependent networks: generowanie syntetycznych grafów, wprowadzanie losowych awarii/ograniczeń zasobów, badanie rozkładu rozmiaru kaskady i wrażliwości na parametry sprzężeń. ²¹

Symulacje scenariuszowe oparte o ramy interdependency (typy zależności, czasy opóźnień, priorytety odbudowy) i testowanie „polityk odbudowy” (np. które węzły naprawiać najpierw) jako problemu optymalizacji odporności. ²³

Table-top exercises (TTX) dla decydentów i operatorów: ćwiczenie nie dotyczy „jak zaatakować”, tylko „jak utrzymać usługi i odzyskać sterowalność” przy równoczesnej degradacji energii i łączności; mapowanie działań na funkcje CSF 2.0 (Govern/Identify/Protect/Detect/Respond/Recover) oraz na standardy OT (IEC 62443). ⁵⁷

Badania nad „cyfrowymi bliźniakami” i detekcją anomalii w OT/ICS w środowiskach testowych: NIST sygnalizował potrzebę uwzględniania nowych technologii (m.in. digital twins, anomaly detection) w aktualizacjach przewodników OT security. ⁵⁸

Metryki odporności, które można stosować w tych badaniach (w warunkach symulacji) obejmują m.in.: czas do wykrycia (MTTD), czas do odtworzenia (MTTR), „obsługiwalny procent” usługi (SLA) w funkcji czasu, rozmiar komponentu największej kaskady, liczbę sektorów wtórnie dotkniętych oraz „koszt sterowalności” (czy operatorzy zachowali możliwość bezpiecznego przełączenia na tryb manualny). ⁵⁹

Źródła

Repozytoria (wskazane przez użytkownika, wykorzystane jako przykłady praktyk inżynierii bezpieczeństwa): ²⁹ ² ⁵² ³ ⁴²

Buldyrev, Parshani, Paul, Stanley, Havlin (2010) „Catastrophic cascade of failures in interdependent networks”. ²¹

Rinaldi, Peerenboom, Kelly (2001) „Identifying, understanding, and analyzing critical infrastructure interdependencies”. ²³

SANS Institute ⁶⁰ / E-ISAC: „Analysis of the Cyber Attack on the Ukrainian Power Grid” (wersja ujawniona w archiwum). ¹⁶

Symantec / analiza Stuxnet (udostępnienie archiwalne). ¹⁴

ESET: materiały dot. Industroyer i zagrożeń dla ICS. ¹⁷

NIST: Cybersecurity Framework 2.0 (w tym tłumaczenie PL). ⁶¹

NIST: SP 800-82 Rev. 3 „Guide to Operational Technology (OT) Security” (oraz kontekst aktualizacji). 62

NIST: SP 800-161r1 (upd1) – C-SCRM. 28

European Union Agency for Cybersecurity 63 : Threat Landscape for supply chain attacks (Publ. Office). 27

ISA/IEC 62443 – przegląd serii standardów. 39

MITRE ATT&CK for ICS (matryca i taktyki). 64

IETF / RFC: BGP – RFC 4271. 30

IETF / RFC: BGP Operations and Security – RFC 7454. 31

RIPE NCC: RPKI i walidacja pochodzenia. 32

MANRS: Route Origin Validation (ROV) – ujęcie dobrych praktyk. 33

ONZ: Rezolucja ZO ONZ A/RES/70/237 dot. ICT w kontekście bezpieczeństwa międzynarodowego. 65

ONZ: dokumenty OEWG (raporty/drafty) – repozytoria UN Digital Library. 66

Rada Europy: Konwencja budapeszteńska (ETS 185) – strona informacyjna. 6

CISA: Coordinated Vulnerability Disclosure (CVD) program/process. 67

ENISA: Vulnerability Disclosure (CVD + rola CSIRT i ENISA). 68

ISO: ISO/IEC 29147:2018 oraz ISO/IEC 30111:2019 – opisy standardów. 12

EIA: Iran – profil energetyczny (electricity, gas, miks). 46

1 4 15 23 38 44 47 49 55 Identifying, understanding, and analyzing critical infrastructure interdependencies. (Journal Article) | OSTI.GOV

https://www.osti.gov/biblio/949367?utm_source=chatgpt.com

2 9 kryptologia-informacyjna-sbom.md

<https://github.com/DonkeyJLove/sbom/blob/main/kryptologia-informacyjna-sbom.md>

3 00_overview.md

https://github.com/DonkeyJLove/glitchlab/blob/master/docs/00_overview.md

5 7 18 65 United Nations

https://digitallibrary.un.org/record/815989/files/A_RES_70_237-EN.pdf?utm_source=chatgpt.com

6 About the Convention - Cybercrime

https://www.coe.int/en/web/cybercrime/the-budapest-convention?utm_source=chatgpt.com

- 8 Tallinn Manual 2.0 on the International Law Applicable to Cyber Operations
https://www.cambridge.org/core/books/tallinn-manual-20-on-the-international-law-applicable-to-cyber-operations/E4FFD83EA790D7C4C3C28FC9CA2FB6C9?pageNum=1&utm_source=chatgpt.com
- 10 30 Information on RFC 4271 » RFC Editor
https://www.rfc-editor.org/info/rfc4271?utm_source=chatgpt.com
- 11 24 67 Coordinated Vulnerability Disclosure Program | CISA
https://www.cisa.gov/coordinated-vulnerability-disclosure-process?utm_source=chatgpt.com
- 12 ISO/IEC 29147:2018 - Information technology — Security techniques — Vulnerability disclosure
https://www.iso.org/standard/72311.html?utm_source=chatgpt.com
- 13 14 22 Nicolas Falliere, Liam O. Murchu, and Eric Chien, Symantec, W 32. Stuxnet Dossier, Version 1.4, February 2011. Not classified. | National Security Archive
https://nsarchive.gwu.edu/index.php/document/21440-document-44?utm_source=chatgpt.com
- 16 SANS and Electricity Information Sharing and Analysis Center, Analysis of the Cyber Attack on the Ukrainian Power Grid, March 18, 2016. Not classified. | National Security Archive
https://nsarchive.gwu.edu/document/15331-sans-and-electricity-information-sharing-and?utm_source=chatgpt.com
- 17 ESET Researchers Discover Industroyer, the Biggest Threat To Industrial Control Systems Since Stuxnet | | ESET
https://www.eset.com/afr/about/newsroom/press-releases-afr/research/eset-researchers-discover-industroyer-the-biggest-threat-to-industrial-control-systems-since-stuxne-1/?utm_source=chatgpt.com
- 19 Atak na sektor energetyczny. CERT Polska opublikował raport techniczny
https://www.nask.pl/aktualnosci/atak-na-sektor-energetyczny-cert-polska-opublikowal-raport-techniczny?utm_source=chatgpt.com
- 20 39 40 ISA/IEC 62443 Series of Standards - ISA
https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards?utm_source=chatgpt.com
- 21 56 Catastrophic cascade of failures in interdependent networks | Nature
https://www.nature.com/articles/nature08932?utm_source=chatgpt.com
- 25 48 51 62 SP 800-82 Rev. 3, Guide to Operational Technology (OT) Security | CSRC
https://csrc.nist.gov/pubs/sp/800/82/r3/final?utm_source=chatgpt.com
- 26 Industroyer: Biggest malware threat to critical infrastructure since Stuxnet | ESET
https://www.eset.com/my/industroyer/?utm_source=chatgpt.com
- 27 ENISA threat landscape for supply chain attacks - Publications Office of the EU
https://op.europa.eu/en/publication-detail/-/publication/601e6a13-f983-11eb-b520-01aa75ed71a1/language-en?utm_source=chatgpt.com
- 28 Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations | NIST
https://www.nist.gov/publications/cybersecurity-supply-chain-risk-management-practices-systems-and-organizations?utm_source=chatgpt.com
- 29 README.md
<https://github.com/DonkeyJLove/sbom/blob/main/README.md>
- 31 60 Information on RFC 7454 » RFC Editor
https://www.rfc-editor.org/info/rfc7454?utm_source=chatgpt.com
- 32 Resource Public Key Infrastructure (RPKI) — RIPE Network Coordination Centre
https://www.ripe.net/manage-ips-and-asns/resource-management/rpki?utm_source=chatgpt.com
- 33 What is route origin validation? - MANRS
https://manrs.org/2020/10/what-is-rov/?utm_source=chatgpt.com

34 41 64 **Matrix - ICS | MITRE ATT&CK®**

https://attack.mitre.org/matrices/ics/?utm_source=chatgpt.com

35 37 43 53 57 59 61 **The NIST Cybersecurity Framework (CSF) 2.0 | NIST**

https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20?utm_source=chatgpt.com

42 **70_observability.md**

https://github.com/DonkeyJLove/glitchlab/blob/master/docs/70_observability.md

52 **README.md**

<https://github.com/DonkeyJLove/swarm/blob/master/security/README.md>

46 63 **eia.gov**

https://www.eia.gov/international/content/analysis/countries_long/iran/?utm_source=chatgpt.com

50 **Rekomendacje dla wzmocnienia ochrony systemów OT | CERT Polska**

https://cert.pl/posts/2024/05/rekomendacje-ot/?utm_source=chatgpt.com

54 68 **Vulnerability Disclosure | ENISA**

https://www.enisa.europa.eu/topics/vulnerability-disclosure?utm_source=chatgpt.com

58 **SP 800-82 Rev. 3, PRE-DRAFT Call for Comments: Guide to Industrial Control Systems (ICS) Security | CSRC**

https://csrc.nist.gov/pubs/sp/800/82/r3/iprd?utm_source=chatgpt.com

66 **Draft final report :**

https://digitallibrary.un.org/record/3896820?utm_source=chatgpt.com